

Manual 37 — Implementación Controlada de Protección de Datos / Habeas Data de Colombia

****Idioma:**** Español de América Latina (es-419)

****Línea base controlada:**** Ley Estatutaria 1581 de 2012, disposiciones aplicables consolidadas en Decreto 1074 de 2015 e instrucciones vinculantes vigentes de la SIC verificadas el 31-08-2026.

****Límite:**** Derechos constitucionales, ley, decreto, instrucciones SIC vinculantes, guía/enforcement SIC, regímenes especiales, contratos y práctica organizacional permanecen separados. Esta es guía de implementación, no asesoría jurídica ni aprobación de la SIC.

Chapter 01 — Propósito, alcance y jerarquía controlada de fuentes

Use principios constitucionales de privacidad/habeas data, Ley 1581, decretos aplicables e instrucciones vinculantes SIC según su verdadero estatus. Mantenga separadas guías, enforcement, regímenes especiales, contratos y procedimientos internos.

Conserve registro fechado de fuentes, owner de aplicabilidad, change watch y reverificación de release.

Chapter 02 — Contexto constitucional de habeas data y privacidad

Mapee derechos constitucionales de acceso, actualización, rectificación, circulación, privacidad y autodeterminación informativa, distinguiéndolos de obligaciones operativas de Ley 1581 y regímenes sectoriales.

Conserve source mapping, policy traceability, procedimientos de derechos y criterios de escalamiento.

Chapter 03 — Aplicabilidad, exclusiones y análisis jurisdiccional

Documente si cada tratamiento cae dentro del régimen general, una exclusión o un régimen especial. No asuma que todas las bases o entidades se regulan igual.

Conserve applicability assessments, hechos, exclusiones, overlays especiales, reviewers y triggers de reevaluación.

Chapter 04 — Categorías de datos y conceptos de tratamiento

Mantenga definiciones controladas de datos personales, sensibles, públicos, privados y semiprivados; tratamiento; base de datos; titular; responsable; encargado y conceptos relacionados.

Conserve glosario, clasificación, ejemplos, decisiones e historial de cambios.

Chapter 05 — Responsable, encargado y accountability

Identifique roles reales según decisiones, instrucciones y hechos, no solo labels contractuales. Defina accountability, escalamiento, rights support, seguridad, incidentes y evidencia.

Conserve matrices, instrucciones, contratos, owners y revisiones.

Chapter 06 — Gobernanza, políticas y supervisión

Establezca gobernanza aprobada con ownership, funciones responsables, oversight ejecutivo, issue escalation, assurance y management review periódico. Integre privacy con security, legal, procurement, HR, producto, data, operaciones y risk.

Conserve policies, RACI, comités, training, dashboards, issues y corrective actions.

Chapter 07 — Inventario, registro de tratamiento y flujos

Mantenga inventario de databases, systems, propósitos, categorías, sensibles, titulares, fuentes, recipients, encargados, ubicaciones, transfers/transmissions, retention, security y owners.

Actualice por cambios de negocio, tecnología, propósito, vendor, flujo o ley.

Chapter 08 — Autorización/consentimiento y excepciones

Cuando se requiera autorización, recoja evidencia informada para propósitos definidos. Cuando exista excepción, documente fundamento y hechos en vez de fabricar consent evidence.

Conserve texto/versión, timestamp, método, propósito, revocación y exception rationale.

Chapter 09 — Avisos de privacidad y deberes de información

Mantenga avisos/policies coherentes con tratamiento real, autorización, propósitos, derechos, identidad del responsable, contactos, datos sensibles, transferencias/transmisiones y condiciones relevantes.

Conserve versiones, approvals, publicación, readability y reconciliación con sistemas.

Chapter 10 — Finalidad, necesidad, proporcionalidad, calidad y circulación restringida

Limite tratamiento y circulación a propósitos legítimos, informados y autorizados o legalmente permitidos. Mantenga calidad razonable, proporcionalidad, necesidad, confidencialidad y access restriction.

Conserve purpose registers, minimization reviews, quality controls, access reviews y remediation.

Chapter 11 — Controles de datos sensibles

Trate datos sensibles como riesgo elevado. Documente propósito, base/autorización, necesidad, transparencia, access restriction, security, sharing, retention y excepciones aplicables.

Conserve inventories, assessments, authorization/exception evidence, access y tests.

Chapter 12 — Datos de niños y adolescentes

Aplique gobernanza reforzada incluyendo interés superior, derechos fundamentales, purpose limitation, transparencia, minimización, security y autorización/excepción legal adecuada.

Conserve context assessment, notices, authorization analysis, safeguards y remediation.

Chapter 13 — Consultas, reclamos, corrección, actualización, supresión y revocación

Opere procedimientos documentados para consultas/reclamos y corrección, actualización, supresión y revocación cuando procedan. Enrute según el proceso vigente y rol de la organización.

Conserve logs, scope, búsquedas, decisiones, respuestas y closure evidence.

Chapter 14 — Validación de identidad, representación, tiempos y evidencia

Verifique identidad/representación proporcionalmente, proteja contra disclosure no autorizado y rastree términos legales y extensiones. Distinga deadlines legales de service targets voluntarios.

Conserve identity evidence, timestamps, correspondence, extensions y metrics.

Chapter 15 — Salvaguardas de seguridad

Implemente controles administrativos, técnicos y físicos proporcionales. Integre IAM, secure configuration, encryption cuando corresponda, logging, vulnerability management, secure development, physical security, monitoring, resilience e incident response.

Conserve mappings, tests, vulnerabilities, exceptions y corrective actions.

Chapter 16 — Incidentes, escalamiento y reporte

Use proceso documentado para determinar afectación de datos, preservar evidencia, evaluar alcance/daño, escalar y cumplir obligaciones SIC/RNBD donde sean aplicables. No trate reportes RNBD como universales sin applicability analysis.

Conserve facts, detection time, assessment, decision authority, reporting evidence y remediation.

Chapter 17 — Riesgo de privacidad y tratamiento de alto riesgo

Evalúe riesgo para sensibles, grupos vulnerables, monitoring, profiling, gran escala, nuevas tecnologías o secondary use inesperado. Aplique controles adicionales y management escalation cuando corresponda.

Conserve methodology, assessments, residual risk, safeguards y approvals.

Chapter 18 — Aplicabilidad y operación del RNBD

Documente si la entidad/bases cumplen criterios vigentes de registro y mantenga registros/updates solo cuando se requieran. Preserve thresholds, categories, update duties, incident relationships y cambios de Circular Única.

Conserve applicability analysis, RNBD records, update logs e incident evidence.

Chapter 19 — Transferencias internacionales y excepciones

Para transferencias donde el receptor actúa como responsable, evalúe destino, condiciones, excepciones, mecanismos de conformidad, autorización u otros requisitos vigentes. No trate una declaración de conformidad como permiso general.

Conserve transfer inventory, recipient role, mechanism/exception, SIC evidence, contracts y reassessment.

Chapter 20 — Transmisiones nacionales/internacionales y contratos de encargado

Para transmissions bajo instrucciones, mantenga acuerdos que definan scope, purpose, security, confidentiality, rights support, incidents, subcontracting, deletion/return y transfer conditions.

Conserve transmission register, agreements, instructions, due diligence y monitoring.

Chapter 21 — Lifecycle de vendors, encargados y terceros

Evalúe terceros antes y durante la relación. Alinee role classification, instructions, purposes, security, rights support, incident cooperation, location, international flows, retention, audit y exit.

Conserve due diligence, contracts, registers, monitoring, findings y termination evidence.

Chapter 22 — Cloud, SaaS, servicios gestionados y responsabilidad compartida

Mappe locations, support access, admins, subprocessors, telemetry, backups, encryption, retention, deletion, controls y flows internacionales. Resuelva roles y cross-border conditions antes de producción.

Conserve architecture/data-flow maps, configurations, shared responsibility, contracts y exit plans.

Chapter 23 — Marketing, analytics, profiling, monitoring y canales digitales

Gobierne marketing, cookies/trackers, analytics, profiling, personalization y monitoring según authorization, notice, purpose, necessity, security y rights. Mappear overlays consumer/e-commerce por separado.

Conserve use-case assessments, basis, notices, configuration evidence y complaints.

Chapter 24 — Datos laborales

Aplique deberes generales a empleados, candidatos y contractors separando normas laborales y otras especiales. Limite access/monitoring a propósitos documentados y controles proporcionales.

Conserve workforce notices, authorization/exceptions, access reviews, retention y training.

Chapter 25 — Retención, archivo, supresión y disposición

Defina retention según propósito, ley, claims, records, contracts y necesidad. Implemente deletion, suppression/blocking, archive, backup y secure disposal conforme al fundamento aplicable.

Conserve schedules, deletion/suppression evidence, legal holds y disposal records.

Chapter 26 — Circulares SIC, investigaciones, sanciones y readiness

Mantenga obligation register que distinga instrucciones/circulares vinculantes de guidance, concepts, FAQs, enforcement facts y propuestas. Prepare respuesta controlada a investigaciones y requerimientos.

Conserve SIC register, investigation protocol, legal holds, response packages, findings y corrective actions.

Chapter 27 — Regímenes sectoriales y especiales

Identifique habeas data financiero/credicio, health, telecom, employment, children, public-sector, consumer, electoral y otros regímenes separados del marco general.

Conserve overlay matrices, applicability decisions, citations, owners y change watch.

Chapter 28 — Arquitectura de evidencia y audit trail

Cree trazabilidad desde requirement/source hasta owner, procedure, system/control, test, exception, remediation y decision. Proteja integrity, access, confidentiality, retention y version history.

Conserve evidence indexes, control maps, workpapers, logs, approvals y provenance.

Chapter 29 — Excepciones, remediación y risk acceptance

Exija excepciones con scope, rationale, compensating controls, owner, approval, residual risk, duration y expiration. Escale issues vencidos/materiales a management y liderazgo legal/privacy.

Conserve exception registers, corrective actions, risk acceptances, dashboards y closure evidence.

Chapter 30 — Reformas y change watch SIC

Monitoree cambios promulgados a Ley 1581/Decreto 1074, Circular Única Título V, RNBD, incidentes, transfer/transmission procedures, reglas corporativas vinculantes, sanciones y overlays. Trate propuestas solo como change-watch hasta vigencia.

Conserve source snapshots, change assessments, implementation plans y effective dates.

Chapter 31 — Exact-hash, localización, provenance y release evidence

Congele controlled source antes del candidate build. Vincule EN/es-419/pt-BR DOCX/PDF a SHA-256 exactos y preserve accessibility, render, localization, source, workflow-security y release-QA.

Todo cambio material post-freeze requiere supersession, regeneration, re-hashing y re-review.

Chapter 32 — Roadmap, madurez y reverificación de release

Implemente por fases: applicability/inventory, authorizations/notices, rights, RNBD, security/incidents, transfers/transmissions/vendors, high-risk uses y assurance/evidence. Mida madurez con outcomes respaldados por evidencia.

Antes de publicar, reverifique Ley 1581/2012, Decreto 1074/2015, Circular Única Título V, RNBD/incidentes, transfer/transmission procedures, procesos de conformidad 2026, binding corporate rules, sanctions/enforcement y reformas promulgadas. Publicación permanece después de Manual 36 con todos los gates en verde.